

● 27 Out 2021

01

US\$ 130M

Cream Finance

”O terceiro ataque ao Cream em um ano”

FLASH LOAN + PRICE MANIPULATION • CRITICAL

Três ataques em 2021: US\$37M, US\$19M e US\$130M — mesma causa raiz

0 que aconteceu

02

Cream Finance era um protocolo de lending (empréstimos) fork do Compound. Já tinha sofrido **dois ataques** no mesmo ano.

No terceiro ataque, o mais devastador, o atacante usou **flash loans** para inflar artificialmente o preço de um token colateral (crYUSD).

O problema central: o **exchange rate** do crYUSD era calculado dentro de um único bloco, sem proteção contra **manipulação atômica**.

O atacante inflou o valor do colateral via flash loan, tomou empréstimos massivos usando esse colateral "inflado", e **saiu com US\$130M** sem devolver nada.

Contrato Vulnerável

03

CONTRATO VULNERÁVEL

SOLIDITY / VULNERABLE

ash =

s | -

```
infla totalCash → // exchangeRate  
dispara → // colateral vale mais do que deveria }
```

Lição

Exchange rates devem ser **resistentes a manipulação em single-block**. Use TWAP ou limite variação por bloco.

Como o ataque funcionou

PASSO 1

Flash loan massivo de DAI + USDC



PASSO 2

Deposita no Cream → recebe crYUSD



PASSO 3

Deposita mais → **totalCash dispara**



PASSO 4

exchangeRate inflado → **crYUSD vale 10x+**



PASSO 5

Usa crYUSD inflado como colateral

Pega empréstimos em ETH, WBTC, USDC...



PASSO 6

Sai com US\$130M · Não devolve nada

● Verifique na Blockchain

05

Transação do Ataqueetherscan.io/tx/0x0fe254...31c92Contrato Creametherscan.io/address/0x44fbe...b322

SMARTCONTRACT ENGINEER

Solidity

Lucas Bispo de Oliv

SMARTCONTRACT

Solidi

Solidity de f

